

Matthew Tran - Advanced Port Scanning

In this lab, I will learn how to combine Metasploit and Nmap to streamline the port scanning process. The goals are to:

- Find open ports on a target system.
- Identify services running on those ports.
- Enumerate services for additional information.
- Save and organize scan results for reporting.

Tools Used

- Kali Linux
- Metasploit Framework (msfconsole)
- Nmap
- PostgreSQL
- Terminal

Skills Learned

- Setting up and using Metasploit's PostgreSQL database for storing scan results
- Creating and managing workspaces in Metasploit to organize penetration testing data
- Using Nmap within Metasploit with `db_nmap` to save scans directly to the database
- Performing targeted TCP and UDP scans to discover open ports and services
- Conducting service version detection and script scanning to gather detailed service information
- Identifying and enumerating remote access services like SSH and RDP
- Cleaning and managing host lists in Metasploit to maintain a focused target scope
- **Advanced command line scanning with Nmap and Metasploit**

1: Database Setup

I start by opening a terminal and preparing the Metasploit environment:

Steps I took:

1. Opened a terminal window.
2. Type **sudo su** to switch to root.
3. Start PostgreSQL **with service postgresql start** (Metasploit requires this database).
4. Initialize the Metasploit database with **msfdb init**.

5. Launch Metasploit with **msfconsole**.
6. Verify database connectivity with **db_status**. Which shows me: [*] connected to msf.

```
msf6 > db_status  
[*] Connected to msf. Connection type: postgresql.  
msf6 > █
```

Metasploit uses PostgreSQL to store scan results, host information, services, and vulnerability data. This setup will create a structured environment where all findings are automatically cataloged for later analysis.

2: Set up workspace

Steps taken:

1. In the msfconsole, type: **workspace --add metasploitable**
2. Verify the workspace with **workspace**. The active workspace is marked with a red asterisk: * metasploitable.

```
msf > workspace --add metasploitable  
[*] Added workspace: metasploitable  
msf > workspace  
default  
* metasploitable
```

I created a dedicated workspace to keep my scans separate and organized, just like a professional penetration tester would for different clients or projects.

3: Check my Ip

I run **ip addr show** to identify my machine's IP and subnet.

10.1.173.156/20

This allows me to exclude my own machine from scans.

4: find the target Metasploitable machine

Steps taken:

1. Opened a new terminal window
2. Became root
3. Typed **nmap -sS -Pn -v -p 22 10.1.173.156/20 | grep 'open'** and **nmap -sS -Pn -p 22 10.1.173.156/20 | grep -B4 'open'**

I then scanned only port 22 across the subnet since it's a known open port on Metasploitable, making it a fast way to locate the target.

The host IP on the Metasploitable machine is 10.1.173.156.

```
(root@kali.example.com)-[/home/student]
# nmap -sS -Pn -v -p 22 10.1.173.156/20 | grep 'open'
Discovered open port 22/tcp on 10.1.161.24
22/tcp open  ssh
Discovered open port 22/tcp on 10.1.173.156
22/tcp open  ssh

(root@kali.example.com)-[/home/student]
# nmap -sS -Pn -p 22 10.1.173.156/20 | grep -B4 'open'
Nmap scan report for ip-10-1-161-24.ec2.internal (10.1.161.24)
Host is up (0.000075s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
--
Nmap scan report for ip-10-1-173-156.ec2.internal (10.1.173.156)
Host is up (0.000038s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
```

- Discovering open ports and services with Metasploit and Nmap

I returned to the terminal window with the Metasploit Framework running at the msf6> prompt.

Steps taken:

1. I typed **db_nmap 10.1.173.156**. I used db_nmap so results would be saved directly into the Metasploit database for easy querying later.
2. Type **db_nmap -F -sS -n -v --open --reason 10.1.173.156** and pressed enter.

To view current host results stored in my workspace I typed **hosts**.

To view the current services stored in my workspace I typed **services**.

I then opened and completed a comprehensive background scan:

1. Typed **sudo su** and pressed enter.
2. Typed **msfconsole** and pressed enter.
3. Typed **workspace metasploitable** and pressed enter.

4. Typed **db_nmap -T4 -p- -sS -n -v --open --reason 10.1.173.156** and pressed enter.

Services found and what ports and protocols were running

Services and Ports:

```
msf6 > db_nmap -T4 -p- -sS -n -v --open --reason 10.1.173.156
[*] Nmap: Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-23 01:13 UTC
[*] Nmap: Initiating SYN Stealth Scan at 01:13
[*] Nmap: Scanning 10.1.173.156 [65535 ports]
[*] Nmap: Discovered open port 3389/tcp on 10.1.173.156
[*] Nmap: Discovered open port 22/tcp on 10.1.173.156
[*] Nmap: Completed SYN Stealth Scan at 01:13, 0.68s elapsed (65535 total ports)
[*] Nmap: Nmap scan report for 10.1.173.156
[*] Nmap: Host is up, received localhost-response (0.0000030s latency).
[*] Nmap: Not shown: 65533 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE      REASON
[*] Nmap: 22/tcp    open  ssh          syn-ack ttl 64
[*] Nmap: 3389/tcp   open  ms-wbt-server syn-ack ttl 64
[*] Nmap: Read data files from: /usr/bin/./share/nmap
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 0.79 seconds
[*] Nmap: Raw packets sent: 65535 (2.884MB) | Rcvd: 131072 (5.505MB)
```

SSH on **port 22/tcp**

Microsoft Remote Desktop on **port 3389/tcp**

The scan revealed that the host 10.1.173.156 has two open ports. SSH (port 22) and Microsoft Remote Desktop (port 3389). Both services are used for remote access and are potential targets for exploitation if not properly checked and secured.

- **Run a UDP scan using Metasploit and Nmap**

I performed a UDP scan to uncover services like DHCP or SNMP that only listen on UDP ports and might be missed by TCP scans.

I typed **db_nmap -sU -n -v --open --reason 10.1.173.156** and found DHCP Client on port 68/udp in an open|filtered state.

```

msf6 > db_nmap -sU -n -v --open --reason 10.1.173.156
[*] Nmap: Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-23 01:17 UTC
[*] Nmap: Initiating UDP Scan at 01:17
[*] Nmap: Scanning 10.1.173.156 [1000 ports]
[*] Nmap: Completed UDP Scan at 01:17, 1.35s elapsed (1000 total ports)
[*] Nmap: Nmap scan report for 10.1.173.156
[*] Nmap: Host is up, received localhost-response (0.0000040s latency).
[*] Nmap: Not shown: 999 closed udp ports (port-unreach)
[*] Nmap: PORT      STATE      SERVICE REASON
[*] Nmap: 68/udp open|filtered dhcpc  no-response
[*] Nmap: Read data files from: /usr/bin/./share/nmap
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 1.42 seconds
[*] Nmap: Raw packets sent: 1045 (49.304KB) | Rcvd: 2088 (127.586KB)

```

Port 68/udp is potentially open or filtered. This port is associated with the DHCP client, which is used for obtaining network configuration parameters. The open|filtered state tells us that Nmap could not determine if the port is open because of the lack of response from the host.

Task 4: Service Version Scanning

I used version detection and default scripts to gather detailed information about the discovered services, which is very important for vulnerability assessment.

I typed **db_nmap -sS -sV -sC -v -n -p 22,3389 10.1.173.156**.

new information was discovered:

Port 22/tcp (SSH):

Service Version: OpenSSH 9.7p1 Debian 5 (protocol 2.0)

RSA key: 81:30:15:af:68:43:a0:7d:42:4d:80:74:b4:96:7f:62

ECDSA key: 8f:05:fb:57:87:35:77:76:bb:e9:12:47:08:c4:07:82

ED25519 key: db:0a:30:9d:ai:6f:29:4a:af:81:d4:67:67:db:3b:04

Port 3389/tcp (Microsoft Remote Desktop):

Service Version: xrdp

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel


```

msf6 > db_nmap -sS -sV -sC -v -n -p 22,3389 10.1.173.156
[*] Nmap: Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-23 01:34 UTC
[*] Nmap: NSE: Loaded 156 scripts for scanning.
[*] Nmap: NSE: Script Pre-scanning.
[*] Nmap: Initiating NSE at 01:34
[*] Nmap: Completed NSE at 01:34, 0.00s elapsed
[*] Nmap: Initiating NSE at 01:34
[*] Nmap: Completed NSE at 01:34, 0.00s elapsed
[*] Nmap: Initiating NSE at 01:34
[*] Nmap: Completed NSE at 01:34, 0.00s elapsed
[*] Nmap: Initiating SYN Stealth Scan at 01:34
[*] Nmap: Scanning 10.1.173.156 [2 ports]
[*] Nmap: Discovered open port 22/tcp on 10.1.173.156
[*] Nmap: Discovered open port 3389/tcp on 10.1.173.156
[*] Nmap: Completed SYN Stealth Scan at 01:34, 0.03s elapsed (2 total ports)
[*] Nmap: Initiating Service scan at 01:34
[*] Nmap: Scanning 2 services on 10.1.173.156
[*] Nmap: Completed Service scan at 01:35, 11.07s elapsed (2 services on 1 host)
[*] Nmap: NSE: Script scanning 10.1.173.156.
[*] Nmap: Initiating NSE at 01:35
[*] Nmap: Completed NSE at 01:35, 0.31s elapsed
[*] Nmap: Initiating NSE at 01:35
[*] Nmap: Completed NSE at 01:35, 0.24s elapsed
[*] Nmap: Initiating NSE at 01:35
[*] Nmap: Completed NSE at 01:35, 0.00s elapsed
[*] Nmap: Nmap scan report for 10.1.173.156
[*] Nmap: Host is up (0.000033s latency).
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 22/tcp    open  ssh          OpenSSH 9.7p1 Debian 5 (protocol 2.0)
[*] Nmap: | ssh-hostkey:
[*] Nmap: |   3072 81:30:15:af:f8:43:a0:7d:42:4d:80:74:b4:96:7f:62 (RSA)
[*] Nmap: |   256 8f:b5:fb:57:87:35:77:76:b8:e9:12:47:08:c4:07:82 (ECDSA)
[*] Nmap: |_  256 db:0a:30:9d:a1:6f:29:4a:af:81:d4:67:67:db:3b:0d (ED25519)
[*] Nmap: 3389/tcp open  ms-wbt-server xrdp
[*] Nmap: Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
[*] Nmap: NSE: Script Post-scanning.
[*] Nmap: Initiating NSE at 01:35
[*] Nmap: Completed NSE at 01:35, 0.00s elapsed
[*] Nmap: Initiating NSE at 01:35
[*] Nmap: Completed NSE at 01:35, 0.00s elapsed
[*] Nmap: Initiating NSE at 01:35
[*] Nmap: Completed NSE at 01:35, 0.01s elapsed
[*] Nmap: Read data files from: /usr/bin/./share/nmap
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 12.22 seconds
[*] Nmap: Raw packets sent: 2 (88B) | Rcvd: 5 (216B)

```

SSH: The target is running OpenSSH 9.7p1 on a Debian-based Linux system. The SSH host keys indicate strong cryptographic support.

RDP: The target is running xrdp, an open-source RDP implementation, on a Linux system. Xrdp is usually associated with Windows, making it a potential attack vector if misconfigured.

This information helps in identifying potential exploits.

Task 5: Cleaning up host list

I would clean the hosts list to remove non-target entries, keeping my results focused and within the authorized scope for professional reporting. That is if I had any extra hosts I did not want on the list.

Steps I would've taken:

1. I type **hosts** in the msfconsole to view my hosts.
2. I type **hosts --d <host IP to delete>** to delete any non-target hosts.

This final screenshot shows the results:

```
msf6 > services
Services
=====

host      port  proto  name      state  info
----
10.1.173.156 22    tcp    ssh       open   OpenSSH 9.7p1 Debian 5 protocol 2.0
10.1.173.156 3389  tcp    ms-wbt-server open   xrdp
```

Displays the services running on the Metasploitable machine (10.1.173.156).

Open ports (22/tcp, 3389/tcp).

Service names (SSH, ms-wbt-server).

Protocols (TCP).

Port 22/tcp: Running OpenSSH 9.7p1 for secure remote access on a Debian system.

Port 3389/tcp: Running xrdp, an open-source RDP service on Linux, allowing remote desktop access.